OSINT Project - Marriott International

Company Selection Brief

Analyst Name: Peace Akinwale
Role: Threat Intelligence Analyst
Project Type: Independent academic OSINT case study (not affiliated with Marriott International)
Company: Marriott International
Sector: Hospitality
Primary Domain: marriott.com

Justification for Selection

Marriott International is one of the largest global hospitality companies with a significant digital presence, including booking systems, customer portals, and loyalty programs. These systems handle sensitive customer data such as personal details, payment information, and travel records. Marriott has experienced multiple high-profile cyber incidents, making it a strong candidate for an OSINT-based security assessment.

Known Cyber History

Marriott has experienced major data breaches where attackers accessed millions of guest records, exposing sensitive information such as names, email addresses, passport details, and travel information.

Expected Findings

- Multiple subdomains (booking, login, support portals)
- Publicly indexed documents (PDFs, reports)
- Employee email patterns
- Internet-facing infrastructure
- Potential misconfigurations or exposed endpoints

Rules of Engagement Acknowledgement

This academic investigation used publicly available information and third-party OSINT services. It was not commissioned or authorised by Marriott International. No exploitation, intrusive scanning, or attempts to access restricted systems were undertaken.

Step 1: Company Profiling (Marriott International)

Marriott International

Marriott International operates franchises, and manages hotels, resorts, and residential properties worldwide. It offers accommodations, online booking services, loyalty programs, and travel-related services.

Size and Global Presence

- Over 9,000 properties worldwide
- Presence in 140+ countries
- Large global workforce
- One of the largest hotel chains globally

Data Held by Marriott

Customer Data: Names, emails, phone numbers, addresses, passport details, travel history
Financial Data: Payment card information, billing details
Loyalty Data: Marriott Bonvoy accounts and preferences

Technology and Systems

Marriott uses cloud infrastructure, AI, big data analytics, IoT systems, and booking platforms to manage operations and enhance customer experience.

Digital Presence

- Main website (marriott.com)
- Booking and reservation systems
- Customer portals
- Mobile apps
- Loyalty program platforms
- Multiple subdomains and regional sites

Cybersecurity History

Marriott has experienced significant data breaches affecting millions of customers, leading to exposure of personal and travel-related data and regulatory consequences. E.g. is the 2018 “Starwood incident”.

Importance of the Project

Marriott stores sensitive data, has a large attack surface, and uses complex systems, making it a high-value target for cyber threats and an ideal case for OSINT analysis.

Final Summary

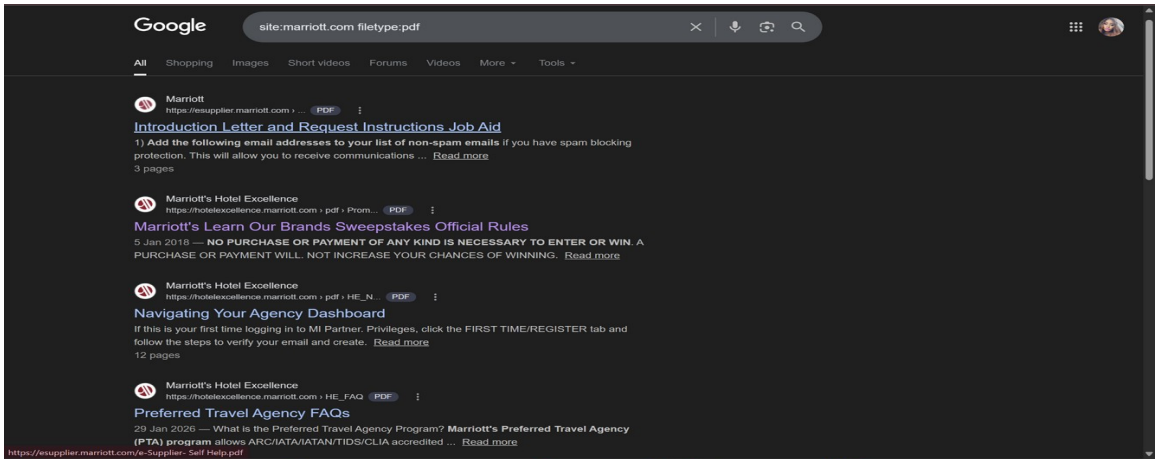
Marriott is a global hotel company that stores sensitive customer data, operates complex digital systems, and has a history of cyber incidents. This makes it highly relevant for identifying potential risks through OSINT.

Step 2: Google Dorking (Marriott International)

Finding 1 – Public Documents

The query `site:marriott.com filetype:pdf` revealed publicly accessible documents hosted on Marriott subdomains such as supplier and hotel excellence platforms. These documents include instructional guides, FAQs, and operational materials.

This information may expose internal processes, system names, and workflows. An attacker could use this information to craft targeted phishing emails or impersonate internal communications, increasing the likelihood of a successful social engineering attack.

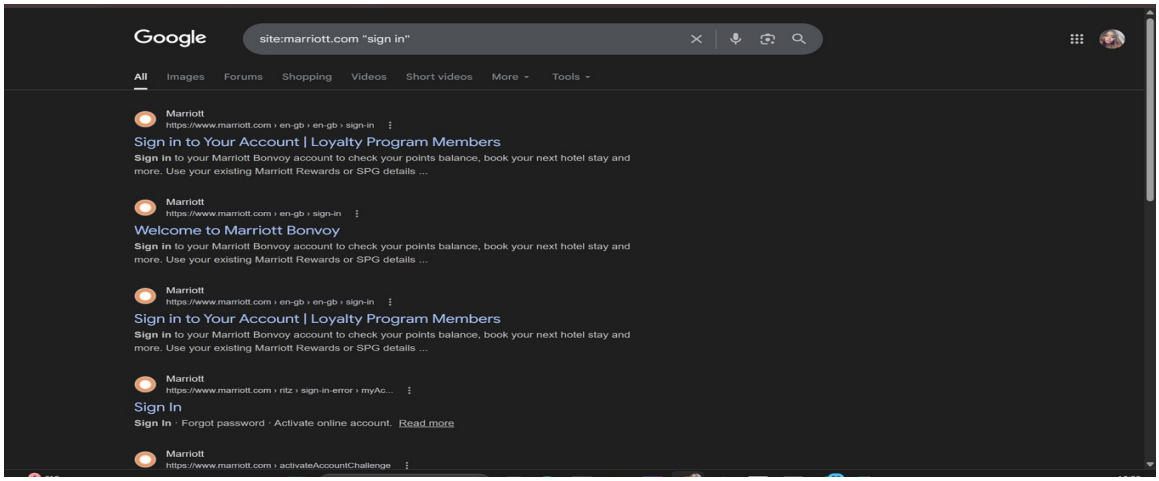


Finding 2 – Login Pages

The query `site:marriott.com intitle:login` identified multiple login portals, including employee and partner access points.

These pages represent authentication surfaces that could be targeted in credential-based attacks such as brute force or credential stuffing. Additionally, attackers could replicate

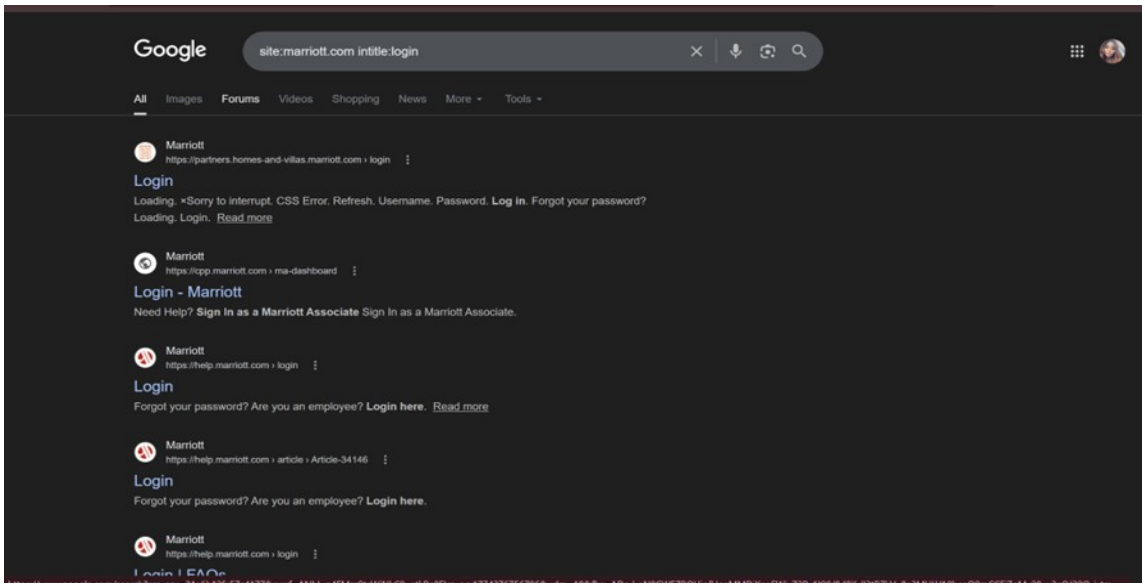
these pages in phishing campaigns.



Finding 3 – Sign-in Pages

The query `site:marriott.com "sign in"` revealed publicly accessible account login pages for Marriott Bonvoy users.

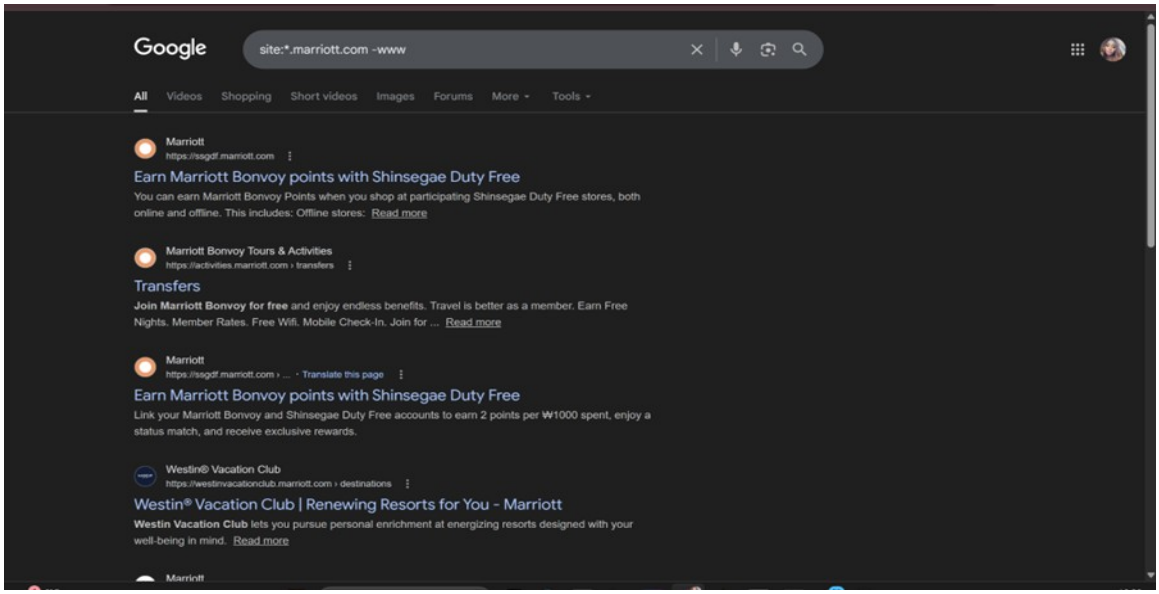
These pages could be used as templates for phishing attacks, where attackers attempt to trick users into revealing their login credentials.



Finding 4 – Subdomains

The query `site:*.marriott.com -www` revealed multiple subdomains associated with Marriott, including services related to travel, loyalty, and partnerships.

The presence of numerous subdomains increases the organisation's attack surface, providing more potential entry points for attackers to explore.

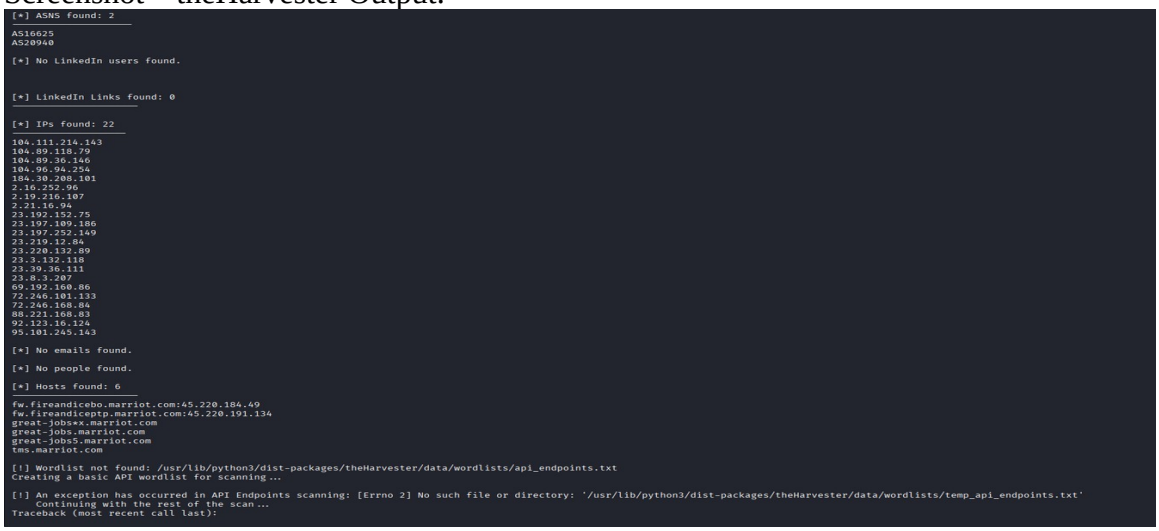


Step 3: theHarvester and Shodan Report

theHarvester via Kali Linux

Using theHarvester with the documented command `theHarvester -d marriott.com -b all`, the investigation reported over 100 subdomain results, associated IP addresses, and no email addresses. The results included infrastructure associated with Akamai (including AS16625 and AS20940), consistent with CDN and traffic-protection services. These observations are indicative and do not establish that every discovered hostname or address is directly owned or operated by Marriott.

Screenshot – theHarvester Output:

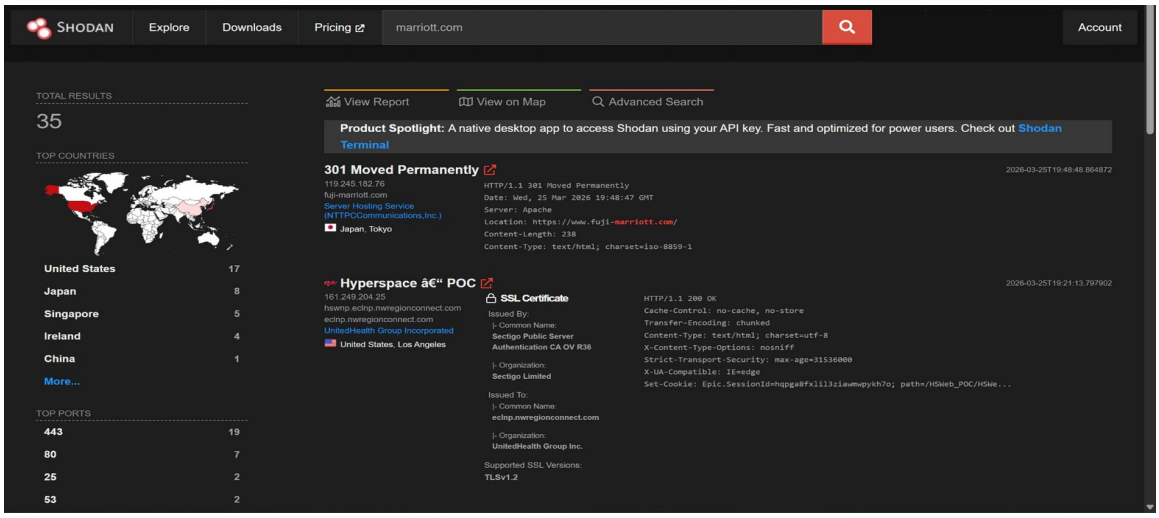


Shodan Findings – Domain Search (marriott.com)

Shodan was used to search the domain **marriott.com** to identify publicly exposed devices and services. The results showed multiple IP addresses across different geographic locations, including the United States, Japan, Singapore, and Ireland.

Several open ports were identified, including **HTTP (80), HTTPS (443), SMTP (25), and DNS (53)**. These ports indicate active services such as web hosting, secure communication, email servers, and domain resolution. These open ports are potential entry points that could be exploited if systems are misconfigured or not properly secured.

Screenshot – Shodan Domain Search:



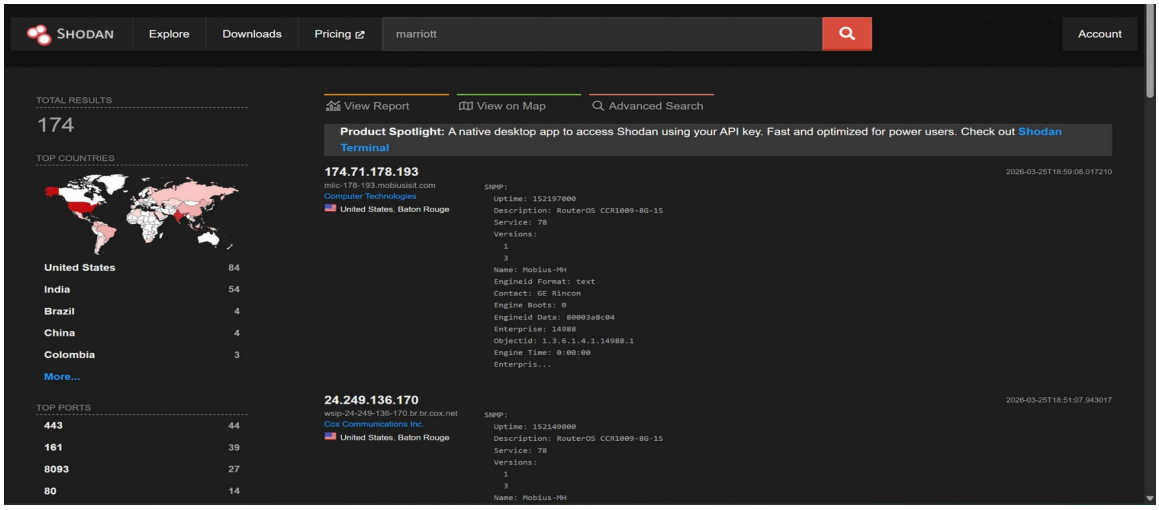
Shodan Findings – Organization Search (Marriott)

Shodan was also used to search for the organization name 'Marriott', which returned a larger number of results compared to the domain search. These included devices distributed across multiple countries such as the United States, India, Brazil, and China.

Additional open ports such as **SNMP (161)** and other services were observed, indicating a wider exposure of networked systems. This broader search demonstrates the scale of Marriott’s digital footprint and highlights additional infrastructure that may not be directly linked to the main domain.

The presence of multiple exposed services increases the organization’s attack surface and could be leveraged for further reconnaissance or exploitation.

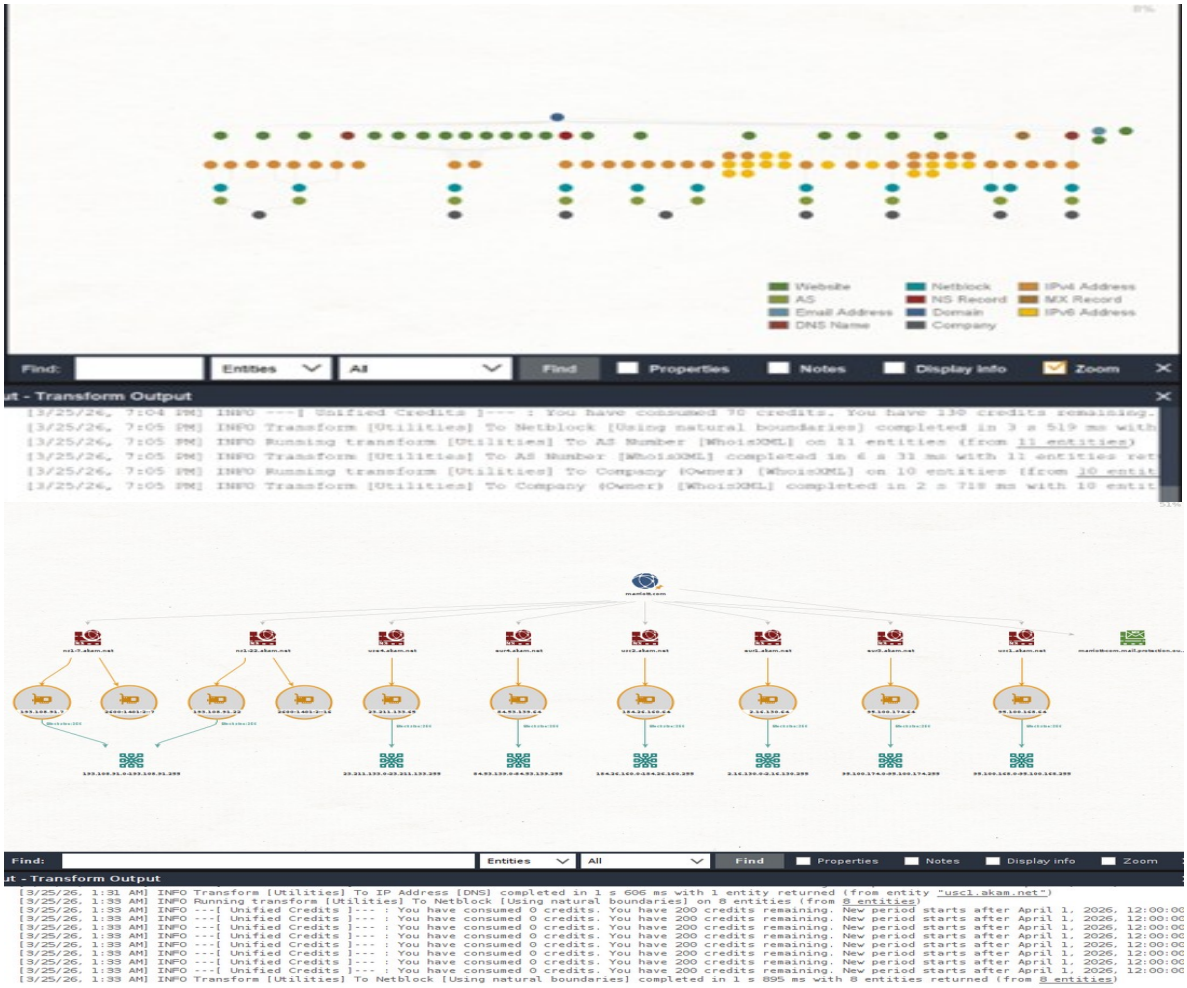
Screenshot – Shodan Organization Search:



Step 4: Maltego Visualization Report - Marriott International

Marriott International was analyzed using Maltego Community Edition to map its footprint between digital entities such as domains, IP addresses, email accounts, and individuals, making it easier to understand how assets are interconnected.

The objective of this analysis is to map the digital footprint of Marriott International by identifying the domain and subdomains, IP addresses and netblocks, email addresses, associated individuals, Infrastructure ownership.



Methodology

The investigation began with the primary domain: **marriott.com** which describes the step-by-step process followed to gather and visualize intelligence on Marriott International using Maltego.

DNS to IP Address

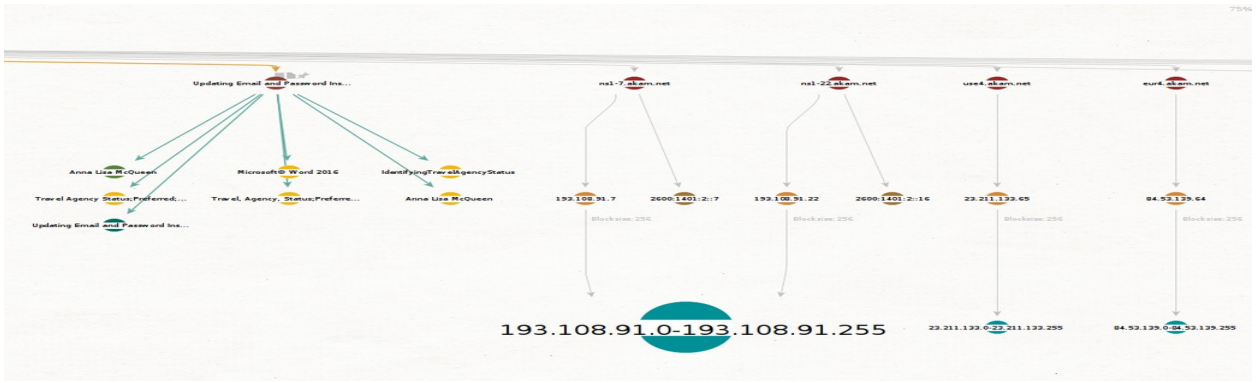
Resolved the domain and subdomains into multiple IP addresses: **193.108.91.7/ 193.108.91.22/ 23.211.133.65/ 84.53.139.64/ 35.100.174.64/ 35.100.168.64**

IP to ASN (Autonomous System Number)

These IPs were further grouped into netblocks such as:

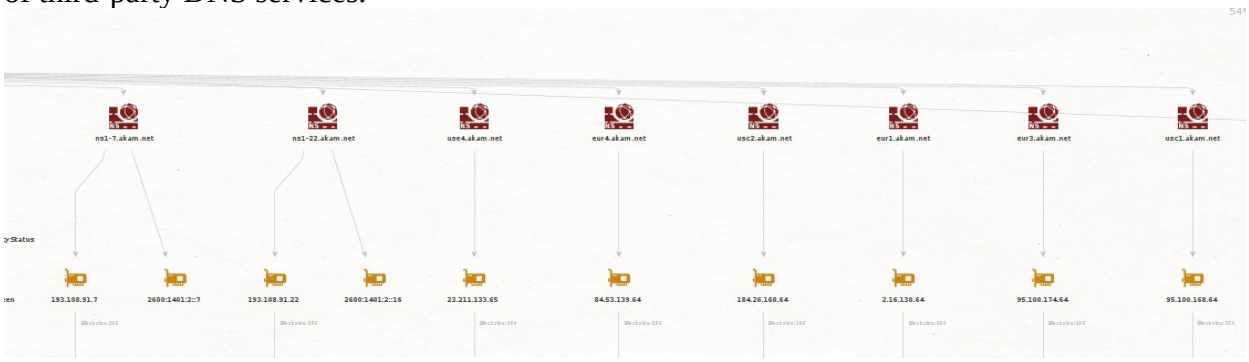
193.108.91.0 – 193.108.91.255/ 23.211.133.0 – 23.211.133.255/ 84.53.139.0-84.53.139.255

The observed IP-to-netblock associations included Akamai infrastructure, consistent with CDN delivery. IP attribution to a third-party provider alone does not prove ownership or operational control by Marriott.

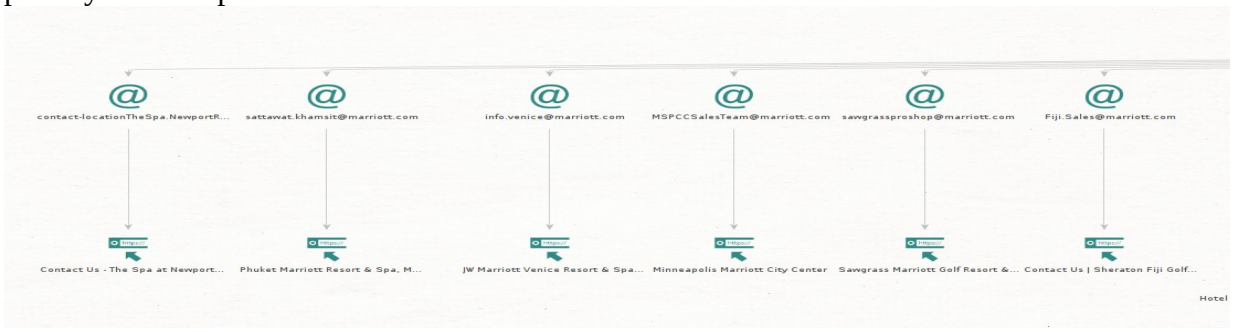


Domain to Subdomains

The mapping included Akamai DNS hostnames such as ns1-7.akam.net, ns1-22.akam.net, use4.akam.net and eur4.akam.net. These are provider infrastructure references rather than Marriott-owned subdomains; their presence is consistent with use of third-party DNS services.



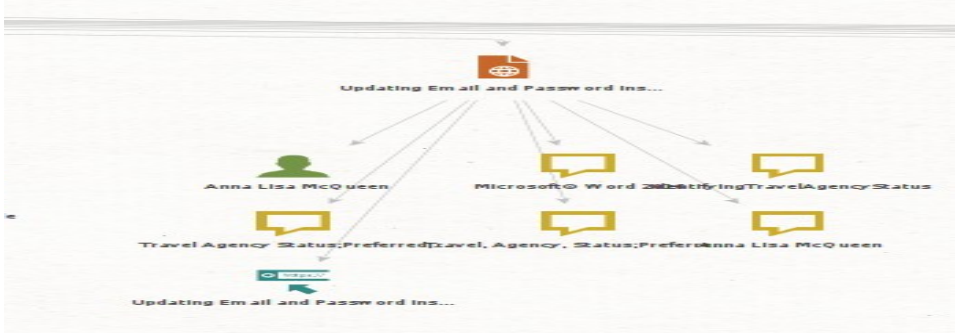
Several email addresses were discovered, such as: affiliate.manager@marriott.com / privacy@marriott.com. These emails were linked to affiliate marketing operations and privacy and compliance functions.



Email to Person

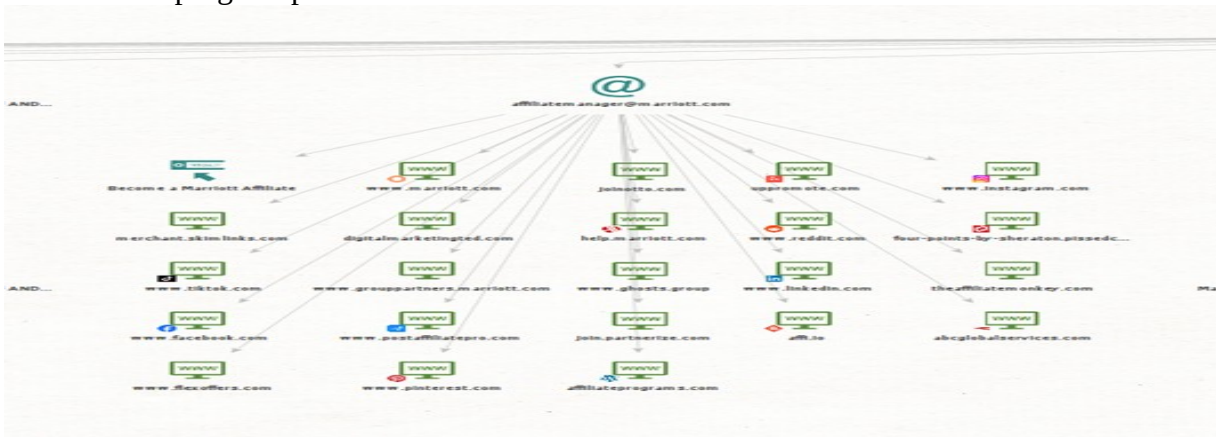
Several emails linked to different people were discovered, one identifiable name was **Anna Lisa McQueen** whose connection was derived through linked documents and

metadata such as: travel agency status**,** account and credential-related workflows.



External Service Integration

This shows Marriott's digital marketing ecosystem, affiliate platforms and social media footprint such as Instagram, Facebook, LinkedIn, TikTok, Pinterest, Reddit, Partnerize, and Affiliate program portal.



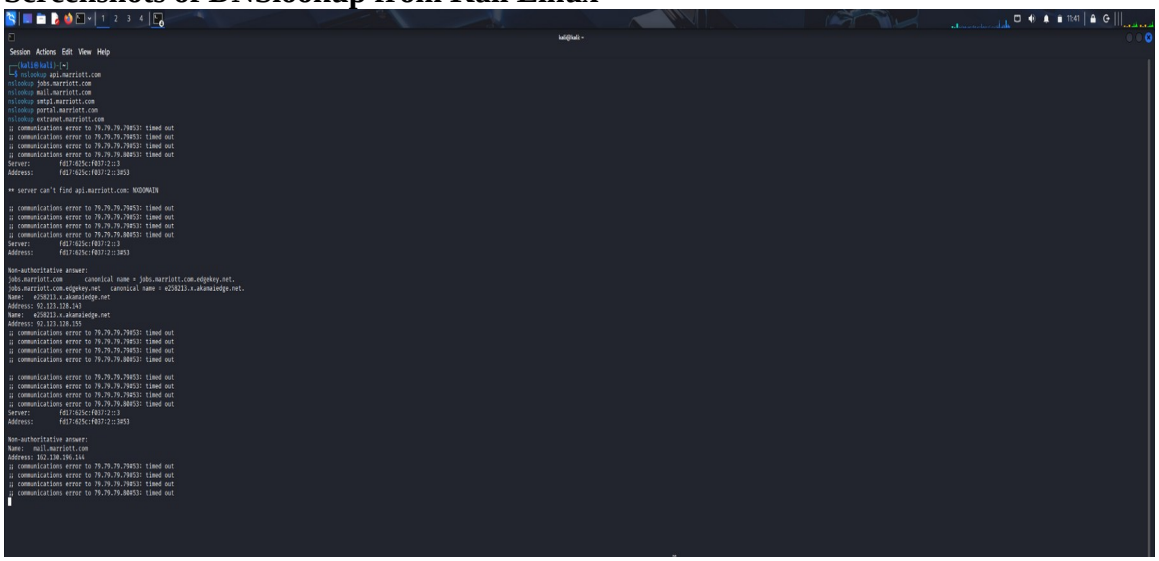
Limitations (Community Edition)

The Maltego Community Edition imposed restrictions such as limited number of results, some subdomains and emails were not discovered and incomplete mapping of ASN and infrastructure depth.

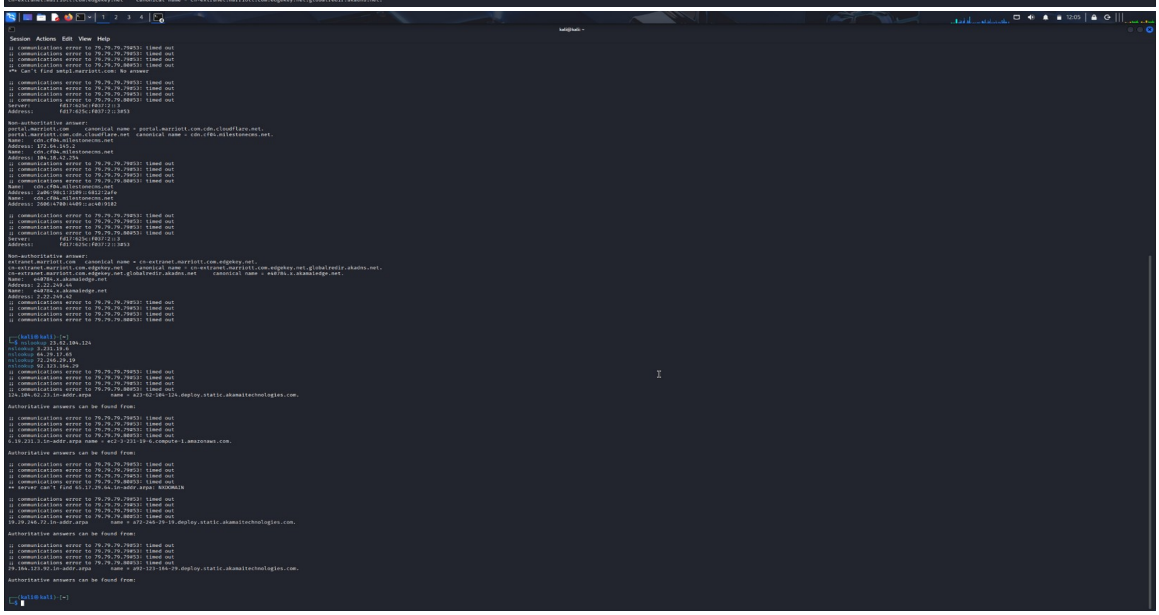
Step 5: Validation - DNS Lookup Findings – Marriott OSINT

This document presents DNS lookup analysis performed using Kali Linux (nslookup).

Screenshots of DNSlookup from Kali Linux







Summary Table

Target	Result	Status
api.marriott.com	NXDOMAIN	Unresolved
jobs.marriott.com	Akamai CDN IPs	Resolved*
mail.marriott.com	Resolved but timeout	Timeout*
smtp1.marriott.com	No response	Unresolved
portal.marriott.com	Cloudflare IP	Resolved*
extranet.marriott.com	Timeouts	Timeout*
23.62.104.124	Akamai reverse DNS	Resolved*
3.231.19.6	AWS reverse DNS	Resolved*
64.29.17.65	No reverse	Unresolved
72.246.29.19	Akamai	Resolved*
92.123.164.29	Akamai	Resolved*

Detailed Analysis

The DNS lookup results included resolved, non-resolving and intermittently responding hostnames at the time of the investigation. Successful DNS resolution indicates that a DNS record was returned; it does not, by itself, establish that an application was reachable or operating normally. Timeouts do not prove that an asset is stale, protected by a firewall or decommissioned. NXDOMAIN indicates that the queried name did not exist in the responding DNS view at that time. Reverse DNS and IP associations with providers such as Akamai and AWS do not independently establish Marriott ownership or an exploitable security issue. These findings should be interpreted as time-specific reconnaissance observations, not verified vulnerabilities.

Step 6: Threat Actor Profiling: Darkhotel vs FIN5

1. Darkhotel - Background

Darkhotel is a suspected South Korean advanced persistent threat (APT) group that has been active since at least 2004, and they are also known by the aliases **DUBNIUM** and **Zigzag Hail**. The group primarily operates in East Asia and target traveling executives, hotels, government officials, and other high-value corporate personnel. Its primary motivation is **cyber espionage**, and it is particularly known for conducting attacks through hotel Wi-Fi networks and compromised online login portals. Darkhotel remains active, with campaigns observed between 2021 and 2023, which includes operations targeted at a luxury hotel in Macao, China. In this campaign, the group used spearphishing emails directed at hotel staff—such as HR personnel, front office employees, and executives—this email contained malicious excel attachments with macros. These were used to execute PowerShell scripts, enabling the attackers to gain access and exfiltrate sensitive data.

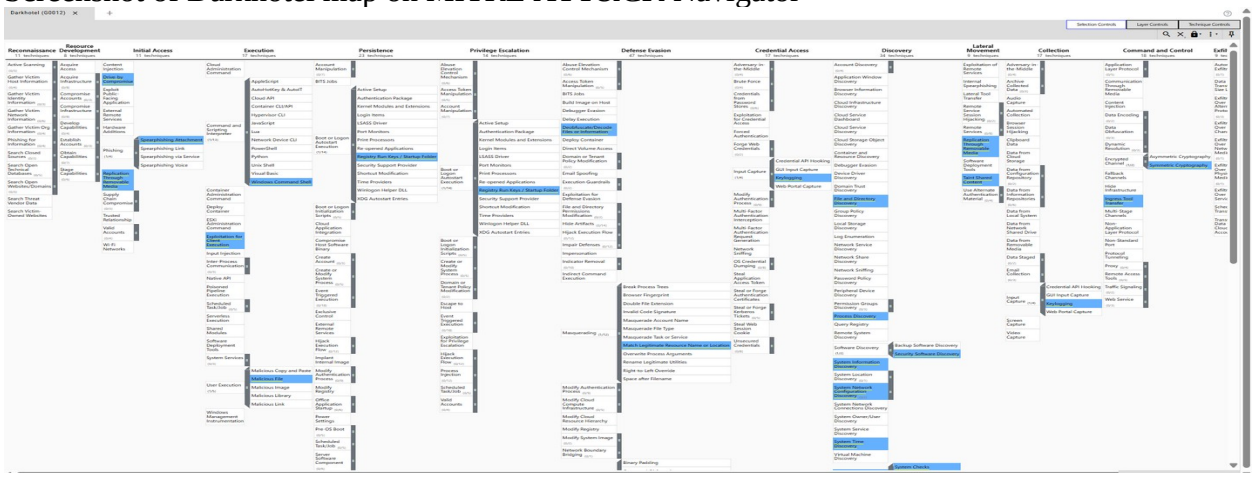
For organizations such as marriott international, Darkhotel poses a significant risk, as it can exploit hotel Wi-Fi infrastructure and guest login details. This could allow the organization to be used as an attack platform, leading to reputational damage and potential data breaches involving high-profile guests.

TTPs (MITRE ATT&CK)		
Tactic	**Technique**	**ID**
Persistence	Registry Run Keys	T1547.001
Execution	Command Shell	T1059.003
Initial Access	Drive-by Compromise	T1189
Initial Access	Spearphishing Attachment	T1566.001
Credential Access	Keylogging	T1056.001
Defense Evasion	Obfuscation (RC4, XOR, RSA)	T1027
Discovery	File Discovery	T1083
Discovery	System Info Discovery	T1082
Discovery	Network Config Discovery	T1016
Collection	Input Capture	T1056
Command & Control	Encrypted Channel	T1573.001
Execution	Exploit (Flash CVE-2015-8651)	T1203
Lateral Movement	Removable Media	T1091
Defense Evasion	Code Signing Abuse	T1553.002
Evasion	Sandbox Evasion	T1497

Indicators of Compromise (IOCs)

Darkhotel IOCs include malicious hotel login redirects, embedded in iframes, fake software updates (such as fraudulent Flash updates), and the presence of malicious files, including .LNK and .RAR attachments.

Screenshot of Darkhotel map on MITRE ATT&CK Navigator



2. FIN5 - Background

FIN5 is a financially motivated cybercriminal group, likely consist of Russian-speaking actors, this group has been active since at least 2008. The group primarily targets restaurants, hotels, and gaming companies, with the objective of financial gain through activities such as payment card theft and the exfiltration of personally identifiable information (PII). FIN5 is known for directly targeting point-of-sale (POS) systems,

payment card data, and customer information. This makes the group a significant threat to organizations, as its operations can lead to substantial financial losses, damage to customer trust, and violations of compliance standards such as PCI-DSS.

In recent activity observed between 2023 and 2024, FIN5 conducted spearphishing campaigns aimed at IT staff and other privileged users. These campaigns used social engineering tactics, including fake tools such as “IP scanner,” to lure victims. Once executed, the attacks deployed malware such as backdoors (e.g., Anunak) and PowerShell-based payloads, enabling unauthorized access and further compromise of targeted systems.

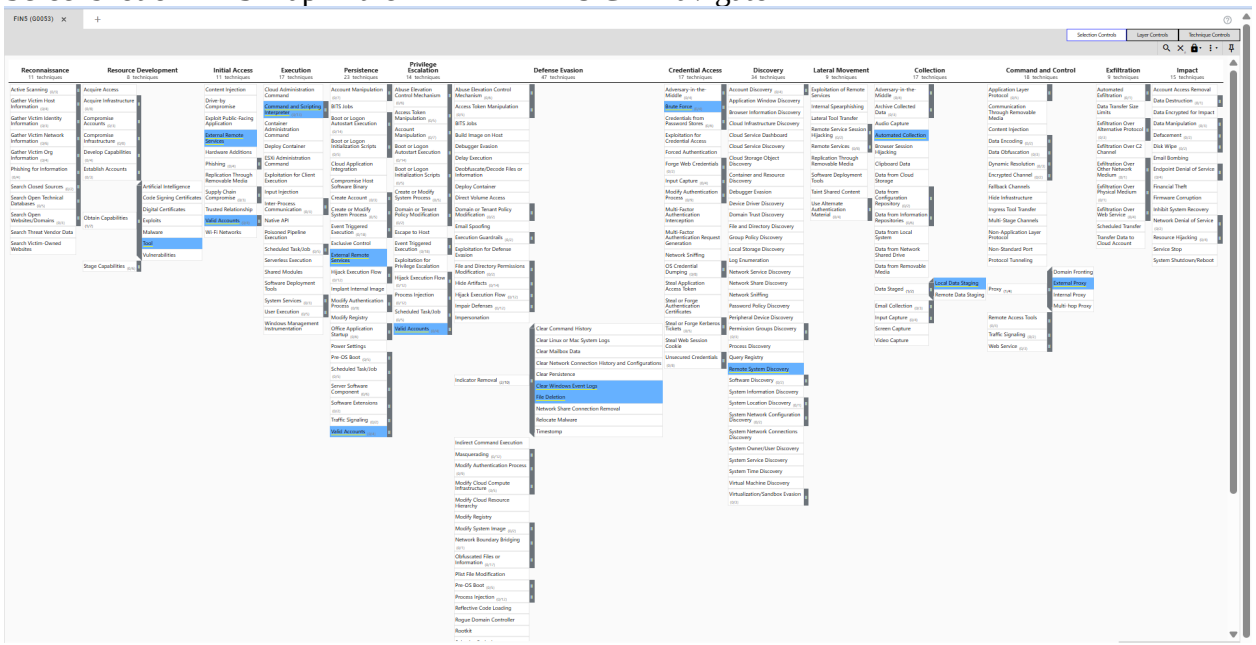
TTPs (MITRE ATT&CK)

Tactic	Technique	ID
Credential Access	Brute Force	T1110
Credential Access	Credential Dumping	T1003
Persistence	Valid Accounts	T1078
Lateral Movement	Remote Services	T1021
Collection	Automated Collection	T1119
Command & Control	Proxy (FLIPSIDE)	T1090.002
Discovery	Remote System Discovery	T1018
Defense Evasion	Clear Logs	T1070.001
Defense Evasion	File Deletion (SDelete)	T1070.004
Exfiltration	Data Staging	T1074.001
Execution	Command Interpreter	T1059

Indicators of Compromise (IOCs)

IOCs associated with FIN5 include the use of tools such as RawPOS, PsExec, SDelete, and pwdump. Additional indicators include unusual VPN or RDP login activity, memory dumping processes targeting POS systems, and evidence of log clearing to avoid detection.

Screenshot of FIN5 map in the MITRE ATT&CK Navigator



Comparison: Darkhotel vs FIN5

Feature	Darkhotel	FIN5
Type	APT (espionage)	Cybercrime group
Motivation	Espionage	Financial
Target	Individuals (VIP guests)	Organizations (hospitality businesses)
Entry Method	Hotel Wi-Fi, phishing	Credential abuse, brute force
Impact	Data espionage	Financial theft (cards, PII)
Sophistication	Very high	High
Scale	Targeted	Scalable

Higher Risk Group: FIN5

For this academic comparison, FIN5 was prioritised as a plausible financial threat scenario because of its reported targeting of hospitality payment environments. This is an analytical judgement, not evidence that FIN5 has targeted Marriott or that it presents a verified higher current risk than Darkhotel.

Risk Assessment

Factor	Risk
Likelihood	🔴 High
Impact	🔴 Very High
Detection	🟠 Difficult
Spread	🔴 High

Recommendations

Based on the identified threats groups like Darkhotel and FIN5, **t**he following recommendations are prioritized for marriott international:

1 Secure Hotel Wi-Fi and Network Infrastructure:

- Network segmentation between guest and internal systems
- Enforce secure captive portals (HTTPS, certificate validation)
- Monitor for rogue access points and malicious redirects

2. Strengthen Phishing Protection and Staff Awareness

- Deploy advanced email filtering and sandboxing tools
- Disable macros by default
- Conduct regular staff training on malicious attachments and social engineering tactics

3. Enforce Multi-Factor Authentication (MFA) and Access Controls

- Prevents misuse of valid accounts
- Monitor abnormal login behavior

4. Strengthen POS System Security

- Implement end-to-end encryption (E2EE) and tokens for card data
- Monitor for Memory scraping and unauthorized tools (e.g., PsExec, pwdump)

5. Deploy Endpoint Detection & Response (EDR)

- Detect PowerShell abuse and credential dumping tools
- Enable automated response to suspicious activity

6. Centralized Logging and Incident Response

- Use SIEM for log aggregation, log deletion events and suspicious authentication activity
- Maintain a tested **incident response plan**

Ethical Considerations

1. Use of Open-Source Intelligence (OSINT)

- Research relied on publicly accessible sources and third-party OSINT tools, including MITRE ATT&CK, search-engine queries, Shodan and Maltego. The report does not claim authorised access to Marriott systems or verification of security vulnerabilities.

2. Respect for Privacy and Confidentiality

- No customer records or restricted employee information were intentionally accessed. Publicly indexed references to individuals or contact addresses should not be treated as evidence of compromise.

3. Legal and Professional Boundaries

- No exploitation, credential testing or intrusive scanning of Marriott systems was undertaken. This independent educational exercise does not constitute a commissioned penetration test or security audit.

Lessons Learned

1. The Human Factor is a Major Weakness as phishing remains highly effective and employees are often the entry point for attacks.

2. Hospitality Industry is a High-Value Target for payment data, personal guest information and act as access points to high-profile individuals.

3. Attackers Combine Multiple Techniques such as infrastructure + espionage, credential abuse + financial theft, thus, security must be layered which are people, process, technology.

4. What Surprised Me

Attackers using: Hotel Wi-Fi as a weapon (Darkhotel) and Legitimate credentials to stay undetected (FIN5)

5. What I Would Do Differently

- Develop a visual MITRE ATT&CK Navigator map
- Include deeper: case studies and real-world breach analysis

Conclusion

This project demonstrates that organizations like Marriott International must adopt a proactive, layered security strategy to defend against both advanced espionage threats and financial cybercrime groups. This brings us to an important fact that cybersecurity is not just prevention, it requires:

- **Detection**
- **Response**
- **Continuous improvement**